GLOBAL BUSINESS SOLUTIONS
FUTURE THINKING. NOW

GBS PROCESS FLOW

POPIA — Organisational Compliance Process Flow

Protection of Personal Information Act 4 of 2013, POPIA Regulations (as amended), Promotion of Access to Information Act 2 of 2000 and Cybercrimes Act 19 of 2020 · As at 19 October 2026

PREPARED FOR
[Client / Team]

PREPARED BY
Global Business Solutions

DATE
19 October 2026

VERSION
v1.0

DOCUMENT STATUS

Working document for legal review — not legal advice.

LAW = in force; REG = regulation; GN = Regulator guidance note; CL = case law; DRAFT = not in force; BP = best practice.

01 / POPIA COMPLIANCE PROCESS

Purpose, status and reading notes

This flow tells a South African private-sector organisation what it must do to comply with the Protection of Personal Information Act, by when, and who hands off to whom. It covers the standing programme (Phase 0), every new or changed processing activity (Phase 1), requests from data subjects (Phase 2), security compromises (Phase 3), dealings with the Information Regulator (Phase 4) and the annual cycle of monitoring and review (Phase 5). An employment track (E) applies the same rules to employee and applicant information, and a parallel track (P) covers events that can arise at any time. It is written for Information Officers (IOs), Deputy Information Officers (DIOs), HR, compliance and legal, IT and information security, marketing and line managers.

Legal status. The Protection of Personal Information Act 4 of 2013 ("POPIA") is fully in force. Most sections commenced on 1 July 2020 and the 12-month grace period in s.114(1) ended on 30 June 2021; ss.110 and 114(4) commenced on 30 June 2021 (Proclamation R21, GG 43461, 22 June 2020). The Regulations Relating to the Protection of Personal Information, 2018 (GN R1383, GG 42110, 14 December 2018) were amended with immediate effect on 17 April 2025 (GN 6126, GG 52523). Regulations on the processing of health information by certain responsible parties, including employers, came into force on publication on 6 March 2026 (GN 7198, GG 54268). The Promotion of Access to Information Act 2 of 2000 ("PAIA") and its 2021 Regulations (GG 45057, 27 August 2021) govern the PAIA manual and access requests. Section 54 of the Cybercrimes Act 19 of 2020 (mandatory reporting to SAPS by electronic communications service providers and financial institutions) has not been put into operation (MJK, reviewed 1 July 2026; re-check before relying on this).

Figures in force. Administrative fine: up to R10 million per infringement notice (s.109(2)(c)); the infringer may pay, arrange instalments or elect trial within 30 days (s.109(2)(d)), and new reg 13 (17 April 2025) sets the case-by-case affordability test for instalments.

Imprisonment: up to 10 years for the s.107(a) offences, up to 12 months for the s.107(b) offences. PAIA request to a private body: decision within 30 days (s.56(1)), one extension of up to 30 days (s.57(1)). PAIA fees for private bodies: request fee R140; search and preparation R145 per hour after the first hour, capped at R435; deposit of one third where search and preparation exceed six hours (PAIA s.54; PAIA Regulations 2021, Annexure B). PAIA annual report window for private bodies: 1 April to 30 June, via the eServices portal.

Labels used throughout.

- **LAW** = Act of Parliament in force; binding now.
- **REG** = regulation in force (POPIA Regulations as amended; health information regulations; PAIA Regulations).
- **GN** = Information Regulator guidance note or published position; not law, but the Regulator applies it in enforcement.
- **CL** = case law (court, year).
- **DRAFT** = proposed or not in force; build readiness, do not treat as a current duty.
- **BP** = best practice or internal control; not a statutory deadline. Adopt it in policy so it binds internally.

Design principle. POPIA sets few hard clocks. It relies on standards such as "as soon as reasonably possible" and "appropriate, reasonable technical and organisational measures". This flow turns each standard into an internal target (BP) that is tight enough to show the Regulator a defensible process. Where the Regulator's guidance is stricter than the Act, the flow follows the guidance as policy and records the difference.

Seven interpretation points that shape the flow.

1. **Counting days.** The amended Regulations define "day" as a calendar day, excluding a last day that falls on a Sunday or public holiday, in line with the Interpretation Act 33 of 1957 (amended reg 1). PAIA periods are also calendar days. Diarise every clock in calendar days from the day after receipt.

2. **"As soon as reasonably possible".** Section 22(2) sets no number of hours. It allows only for the legitimate needs of law enforcement and the steps needed to determine the scope of the compromise and restore the integrity of the system. The flow sets a BP target of 72 hours from reasonable belief to Regulator notification. Any delay beyond that needs a written reason, because the eServices notification asks for the reason for delay.

3. **Responsible party, operator and group structures.** Each legal entity in a group is a separate responsible party and must register its own IO and DIOs (IO guidance note, para 5.3). A vendor that processes for the organisation is an operator and needs a written s.21

contract. One KwaZulu-Natal High Court decision treated an employee as bound by s.20 operator duties (*Zulu Nyala Game Ranch v Beukes*, KZD 2025); that reading is novel and has not been tested on appeal.

4. **Juristic persons are data subjects.** "Personal information" includes information about an identifiable, existing juristic person (s.1). Supplier, client and business-to-business data are in scope, which matters for direct marketing and B2B databases.

5. **Consent is one ground, not the default.** Section 11(1) lists six justifications. In employment, contract (s.11(1)(b)), legal obligation (s.11(1)(c)) and legitimate interest (s.11(1)(f)) usually fit better than consent, which an employee can withdraw and which may not be freely given. Special personal information and children's information need a s.27 or s.35 authorisation as well as a s.11 ground.

6. **Two access routes.** A data subject asking for their own information uses POPIA s.23, but the manner of access and the refusal grounds come from PAIA (s.23(4), s.25). Treat every access request as a PAIA request to a private body for timing (30 days) unless it is a simple confirmation, which is free (s.23(1)(a)).

7. **Guidance notes bind in practice.** Guidance notes are not law, but the Regulator's Enforcement Committee applies them. Examples are the direct marketing guidance note (3 December 2024), which treats telephone calls as electronic communication, and the 2024 revised prior authorisation guidance. Follow them unless legal advice supports a different reading, and record the reasoning.

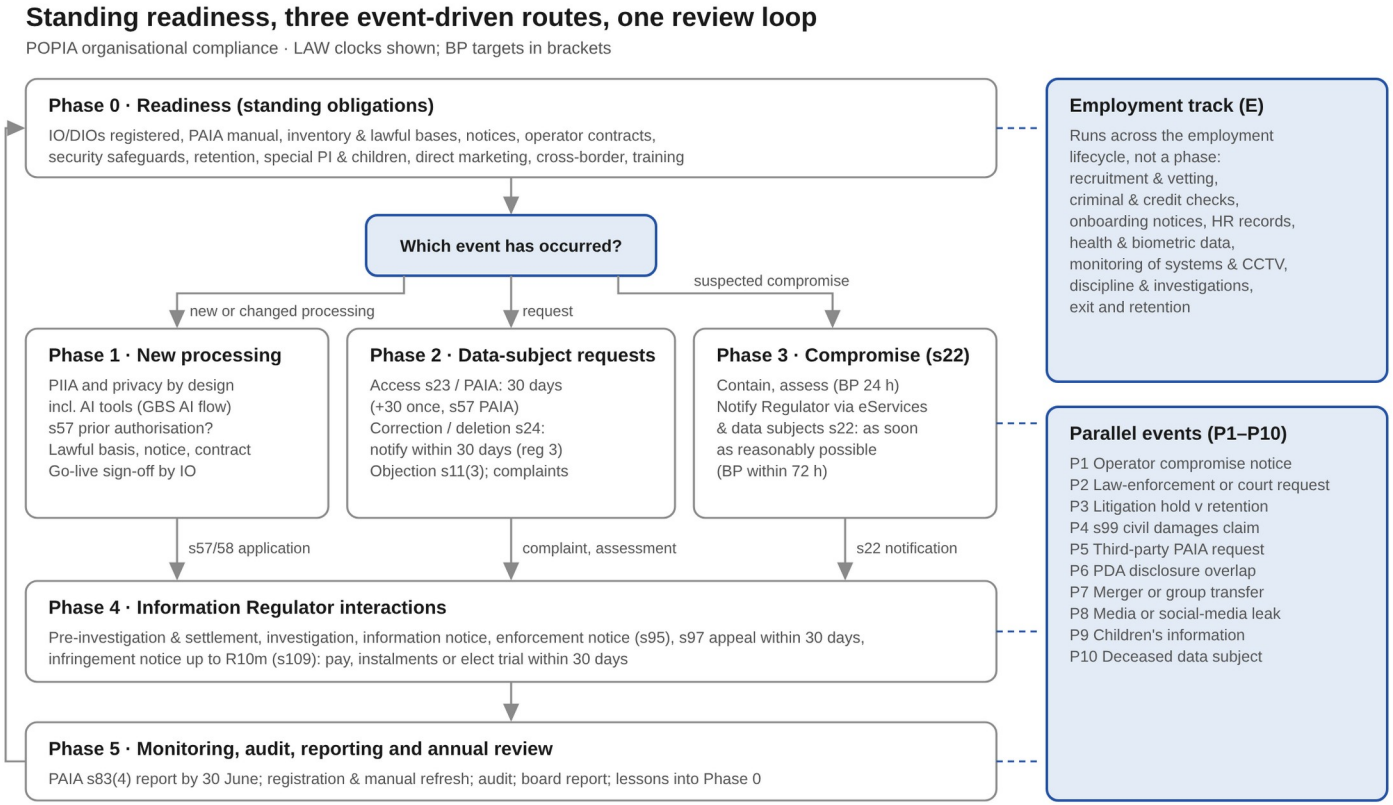
Roles used. Information Officer (IO, by law the head of the private body or the person they authorise in writing); Deputy Information Officer (DIO); Privacy Steering Committee (PSC); Board or EXCO (BOARD); Human Resources (HR); Line Manager (LM); Compliance and Legal (CL); Information Security Officer and IT (ISO); Marketing (MKT); Procurement and vendor management (PROC); Internal Audit (IA); Occupational health practitioner (OHS); Designated Officer under the GBS PDA flow (DO); Operator or vendor (OP); data subject (DS); Information Regulator (IR).

KEY MESSAGE

Accountability sits with the organisation, not the IO.

The responsible party must ensure the conditions for lawful processing are met (s.8). The IO coordinates and reports, but the Board resources the programme and answers for it. Since May 2026 the Regulator has ordered at least one employer to produce a full compliance framework within a fixed period (Central Johannesburg TVET College enforcement notice, 22 May 2026).

Master flow at a glance



Every route closes in Phase 5; findings loop back into Phase 0. Phase 4 opens only when the Regulator is engaged.

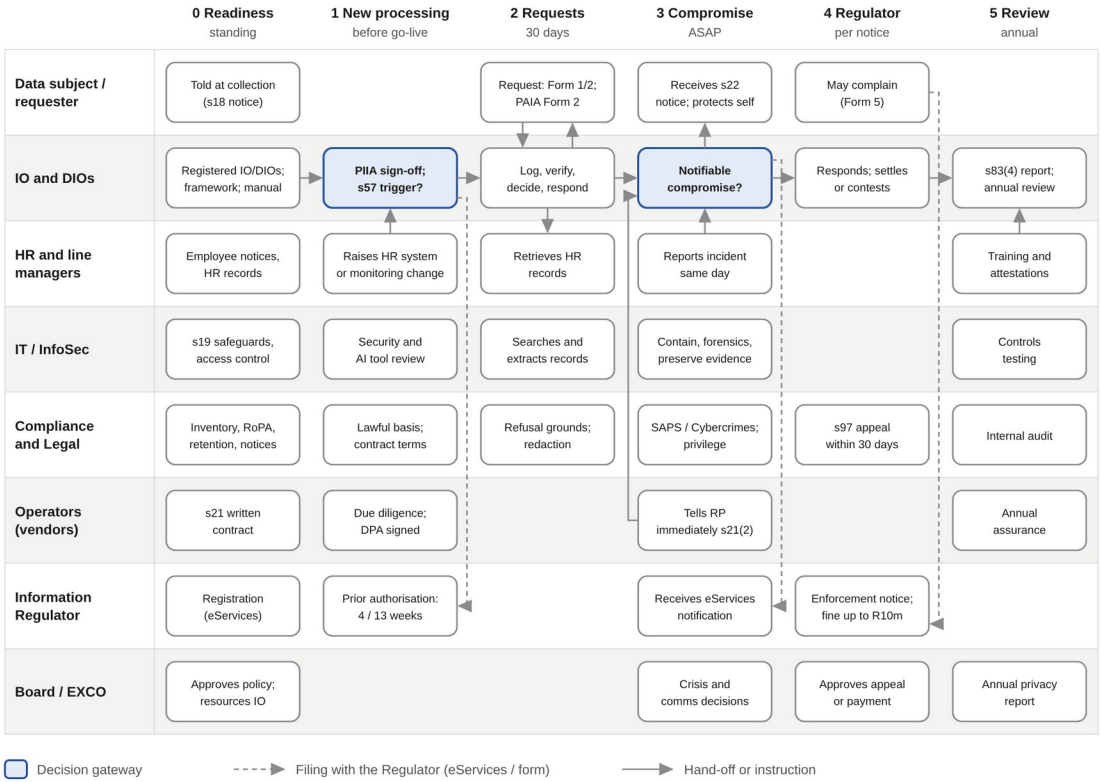
Phase 0 is permanent. Each event (a new or changed processing activity, a data-subject request, a suspected compromise) runs through its own phase. The matter enters Phase 4 only when the Regulator is involved: a prior authorisation application, a complaint, an assessment, or a s.22 notification that leads to questions. Every route closes in Phase 5, and lessons from Phase 5 change the Phase 0 controls. The employment track and the parallel events run alongside every phase.



Integrated swimlane view

Eight lanes, one programme: who acts at each phase

Integrated swimlane · the IO lane is the spine; statutory clocks in the column headers



Read each column top to bottom to see who acts in that phase. Read each lane left to right to see one party's whole job. The IO lane is the spine: every request, change and incident passes through it. Dashed lines are formal filings with the Regulator, through the eServices portal or a prescribed form. Operators never notify the Regulator for the organisation. They tell the responsible party immediately (s.21(2)), and the responsible party notifies.

Phase 0 — Readiness (standing obligations)

Phase 0 has no trigger. It must exist before the organisation can show the Regulator that it complies, and it is the first thing the Regulator asks for in an assessment or after a compromise. The enforcement notices issued to date show the pattern. In 2023 the Department of Justice was fined R5 million because licences for its security software had lapsed (s.19; the fine is under court challenge). In 2023 Dis-Chem was ordered to put a written operator contract in place (s.21). In 2026 the Central Johannesburg TVET College was ordered to register its IO and DIOs within 31 days and to produce a compliance framework (s.8, s.55(2)). Each was a Phase 0 failure.

Step	Organisational action	Owner	Deadline	Form / output	Authority
0.1 Confirm the IO	The head of the private body is the IO by law (the CEO or equivalent for a company). If the head authorises someone else, do it in writing on a template substantially similar to the Regulator's Annexure C. The person should be at management level or above. The head stays accountable and may withdraw the authorisation in writing. For a multinational, authorise a person in South Africa.	BOARD, CEO	Now; on every change of head	PO01 IO authorisation	LAW POPIA s.1 "information officer", s.55; PAIA s.1 "head"; GN IO guidance note (1 April 2021) paras 5.1–5.9
0.2 Designate DIOs	Designate in writing as many DIOs as needed to make the IO accessible, for example per site, business unit or for HR. Only employees may be DIOs. Put the delegated duties in their job descriptions. Delegation must also be in writing, and the IO keeps accountability.	IO	Now	PO02 DIO designation and delegation	LAW POPIA s.56; PAIA s.17; GN IO guidance note paras 7–8
0.3 Register with the Regulator	Register the IO and every DIO on the Regulator's eServices portal before they take up their duties. Each subsidiary registers separately. Check the details at least once a year and update them within 30 days of any change (BP). The details must match the PAIA manual.	IO, CL	Before duties start; review annually	PO03 registration confirmation	LAW POPIA s.55(2), s.8; GN IO guidance note paras 6.6, 10, 11.1–11.2; enforcement notice CJC TVET College (22 May 2026, relied on s.8)



Step	Organisational action	Owner	Deadline	Form / output	Authority
0.4 Governance and policy	Board adopts a POPIA policy and privacy governance charter: roles, PSC terms of reference, risk appetite, reporting lines, budget, sanctions for breach (linked to the Misconduct flow). The IO develops, implements, monitors and maintains the compliance framework, and the framework must be "continually improved".	BOARD, IO	Now; review annually	PO04 policy and charter	LAW s.8, s.55(1); REG reg 4(1)(a) as amended 17 April 2025
0.5 PAIA manual	Compile the s.51 manual: contact details of the head, IO and DIOs; the Regulator's PAIA guide; categories of records held and records available without a request; and for POPIA, purposes of processing, categories of data subjects and information, recipients, planned cross-border transfers and a general description of security measures. Publish it on the website and keep it at the head office. Give a copy to anyone who asks; a reasonable fee may be charged for a hard copy. Update it regularly (BP: annually and on any change). The former POPIA reg 4(1)(c) manual duty was deleted on 17 April 2025, so the duty now rests on PAIA s.51 alone; wilful or grossly negligent failure by the head is an offence (PAIA s.90(3)).	IO, CL	Now; update on change	PO05 PAIA manual	LAW PAIA s.51(1)–(3), s.90(3); POPIA s.17; GN IO guidance note para 6.2.3
0.6 Personal information inventory and RoPA	Map every processing activity: data subject category; information fields; special or children's information; source; purpose; lawful ground; system and location; operator; recipients; cross-border flow; retention period; security owner. This is the documentation s.17 requires and the base for the PAIA manual, PIIAs and breach scoping.	CL, IO with business owners	Now; review annually and on change (Phase 1)	PO06 inventory and RoPA	LAW s.17, s.8; REG reg 4(1)(b) (PIIA)
0.7 Lawful basis and purpose map	For each activity, record the s.11(1) justification, the specific purpose (s.13), minimality (s.10) and whether further processing is compatible (s.15). Where the ground is legitimate interest, keep a short balancing note. Where it is consent, record how consent is captured, refreshed and withdrawn.	CL	With 0.6	PO07 lawful basis register	LAW s.9–s.11, s.13, s.15

Step	Organisational action	Owner	Deadline	Form / output	Authority
0.8 Privacy notices	Issue s.18 notices at or before collection for every data-subject group: customers, website users (with cookies), job applicants, employees, contractors, visitors and CCTV subjects, suppliers' contacts. Include the right to object (amended reg 2) and the right to complain to the Regulator. Where information comes from a third party, notify as soon as reasonably practicable.	CL, MKT, HR	Before collection	PO08 notice set	LAW s.18(1)–(4); s.11(3); REG reg 2 as amended
0.9 Operator contracts	Identify every operator, such as payroll bureaus, cloud and SaaS providers, background-check agencies, hotline providers, AI tool vendors and call centres. Sign a written contract requiring s.19 safeguards, confidentiality, processing only on instruction, notification of compromises immediately, sub-operator controls, cross-border terms, audit rights, and return or destruction at the end.	PROC, CL, ISO	Before processing starts; remediate legacy contracts now	PO09 operator agreement; PO10 due diligence	LAW s.20, s.21(1)–(2); enforcement notice Dis-Chem (2023)
0.10 Security safeguards	Identify all reasonably foreseeable internal and external risks; maintain safeguards; verify that they work; update them in response to new risks. Have due regard to generally accepted information security practices (for example ISO/IEC 27001 or the CIS Controls). Minimum set: access control and MFA, patching, licence and support renewal, encryption, logging, backups, phishing training, and an incident response plan tested at least annually (BP).	ISO	Now; continuous	PO11 security policy and control matrix	LAW s.19(1)–(3); DoJ infringement notice (2023, R5 million, under challenge); SABS enforcement notice (August 2026)
0.11 Retention and destruction	Set a retention period for each record type. Keep records only as long as needed, unless a law, contract, consent or lawful purpose requires longer (s.14(1)). Where a record was used to make a decision about a person, keep it long enough for them to request access (s.14(3)). Destroy or de-identify records so that they cannot be reconstructed (s.14(4)–(5)). Restrict rather than delete where the data subject contests accuracy or the record is needed as evidence (s.14(6)). Align with employment retention laws (track E).	CL, ISO, HR	Now; destruction run quarterly (BP)	PO12 retention schedule; destruction certificate	LAW s.14; BCEA s.31; Tax Administration Act s.29 (verify periods per record)

Step	Organisational action	Owner	Deadline	Form / output	Authority
0.12 Special personal information and children	Identify every processing activity involving religious or philosophical beliefs, race or ethnic origin, trade union membership, political persuasion, health or sex life, biometrics, or criminal behaviour (s.26). Also identify any processing of information about children under 18. For each, record the s.27–s.33 or s.35 authorisation. Apply the 2026 health information regulations to all employee health records: a duty of confidentiality for everyone with access (arising by law, office, employment, profession or written agreement; a signed PO42 undertaking is BP evidence), appropriate safeguards and access control, secure disposal, and s.72 controls on cross-border transfers.	CL, HR, ISO	Now	PO13 special PI register; PO42 health confidentiality undertaking	LAW s.26–s.35; REG health information regulations GN 7198 (6 March 2026)
0.13 Direct marketing	Unsolicited electronic direct marketing (email, SMS, WhatsApp, push notification, social-media DM and, in the Regulator's view, telephone calls) needs consent, or an existing customer relationship that meets s.69(3). Ask a non-customer for consent only once, on a form substantially similar to Form 4. An opt-out is not consent. Record telephone consent requests. Every message must identify the sender and give an opt-out. Keep a suppression list. Register with the National Consumer Commission's National Opt-Out Registry and screen lists against it monthly (CPA; see the GBS CPA flow).	MKT, CL	Now; registry registration by December 2026	PO14 consent record and suppression list	LAW POPIA s.69, s.11(3)(b); REG reg 6 and Form 4 as amended; GN direct marketing guidance note (3 December 2024); LAW CPA s.11 and CPA Amendment Regulations 2026 (NCC statement, 7 October 2026; Gazette number to be confirmed)
0.14 Cross-border transfers	List every transfer outside South Africa, including cloud hosting, group shared services and offshore support. For each, record the s.72(1) basis: a law, binding corporate rules or binding agreement giving adequate protection; consent; necessity for a contract with the data subject or in their interest; or benefit to the data subject where consent is impracticable. Special or children's information sent to a country without adequate protection needs prior authorisation (s.57(1)(d)).	CL, ISO	Before transfer	PO15 transfer assessment	LAW s.72(1)(a)–(e), s.57(1)(d); REG health regs (health information)

Step	Organisational action	Owner	Deadline	Form / output	Authority
0.15 Prior authorisation screen	Screen the inventory for the four s.57(1) categories: (a) unique identifiers used for a different purpose and linked with information from other responsible parties; (b) information on criminal behaviour or unlawful or objectionable conduct processed on behalf of third parties; (c) credit reporting; (d) special or children's information sent to a foreign third party without adequate protection. Each needs prior authorisation once, not each time, unless the processing changes (s.57(3)). Prior authorisation is required for s.57 processing that began on or after 1 July 2021, and for further processing after that date (guidance note paras 6.1–6.2). Since 1 February 2022 such processing may not continue until the Regulator has decided (s.58(2); para 3.2). Any unauthorised processing must stop and an application must be lodged.	CL, IO	Now; on change (Phase 1)	PO16 screening record	LAW s.57–s.59; GN revised prior authorisation guidance (January 2024) paras 3.2–3.4, 6.1–6.2
0.16 Codes of conduct and exemptions	Check whether a code of conduct issued under Chapter 7 covers the sector. If it does, comply with it; a code also removes the need for prior authorisation for the processing it covers. Consider whether a s.37 exemption is needed. Apply by the channels the Regulator prescribes (prior authorisation guidance note para 6.3: email, post or hand delivery; use eServices if the Regulator offers it).	CL	Now; annually	PSC minute	LAW s.37, s.60–s.68; GN prior authorisation guidance paras 3.4, 6.3; REG reg 5 and Form 3 as amended
0.17 Request and complaint handling	Set up the internal machinery to receive and track objections, access, correction and deletion requests, and complaints. Accept every channel the Regulations allow (hand, post, email, SMS, WhatsApp, telephone). Requests and objections are free of charge. Record and keep telephone objections and requests; provide a transcript on request.	IO, DIOs	Now	PO21 request log; PO22 ID checklist	LAW s.23–s.25, s.11(3); REG reg 4(1)(d), regs 2–3 as amended
0.18 Incident response readiness	Approve an incident response plan covering roles, severity matrix, forensic and legal retainers, notification templates, the eServices login held by the IO and at least one DIO, the SAPS reporting route, and media lines. Test it at least once a year in a tabletop exercise (BP).	ISO, IO, CL	Now; test annually	Incident plan; PO30 severity matrix; PO32 template	LAW s.19, s.22; GN security compromise guidance and eServices reporting (since April 2025)

Step	Organisational action	Owner	Deadline	Form / output	Authority
0.19 Training and awareness	Run awareness sessions for all staff at induction and every year, and role-based training for HR, marketing, IT, call centres and managers. Staff sign a confidentiality undertaking. IOs and DIOs should be trained, but the Regulator does not provide training.	HR, IO	Induction; annually	PO17 training record	REG reg 4(1)(e); GN IO guidance note paras 9.1–9.2; CJC TVET enforcement notice (training ordered within 90 days)
0.20 Board reporting	The IO reports to the Board at least twice a year (BP) on the register of processing activities, open requests, incidents, Regulator matters, audit findings and the remediation plan.	IO	Six-monthly (BP)	PO37 board report	LAW s.8, s.55(1)(d); BP

Data-subject side of Phase 0. Nothing is owed by data subjects yet. Their later rights depend on this phase: an organisation without a manual, notices or a request channel cannot show that it informed people of their rights (s.18(1)(h)) or that a request route was reasonably accessible (amended reg 2).

Hand-offs. BOARD → IO (authorisation and resources). IO → IR (registration). PROC → CL (operator contracts). ISO → IO (security posture). HR → IO (employee notices and HR inventory). MKT → CL (consent design). CL → website owner (manual and notices published).

Watch. Registration is the first thing the Regulator checks and the easiest finding against an organisation. In May 2026 the Enforcement Committee ordered a college to register its IO and DIOs within 31 days, together with wider orders. Keep the eServices confirmation, and re-register promptly whenever the CEO changes, because the head of the body is the IO by operation of law.

04 / POPIA COMPLIANCE PROCESS

Phase 1 — New processing, change and privacy impact assessment

Every new system, process, product, vendor, data-sharing arrangement or AI tool, and every material change to an existing one, must pass through Phase 1 before go-live. The trigger is the decision to change, not the go-live date. The Regulations require the IO to ensure

that a personal information impact assessment (PIIA) is done (reg 4(1)(b)). The Regulator has said it plans a PIIA guidance note in its 2026/27 year (DRAFT; verify).

Step	Trigger	Organisational action	Owner	Deadline	Form	Authority
1.1 Intake and screen	A project, procurement, data-sharing, analytics or AI request involving personal information.	Business owner completes a short screening form: what data, whose, why, which system or vendor, which countries, any special or children's information, any automated decisions, any monitoring. Without a screening reference, procurement cannot raise an order (BP).	Business owner, PROC	At project initiation	PO18 PIIA (screening part)	REG reg 4(1)(b); BP
1.2 Decide depth of assessment	Screening done.	A full PIIA is needed if any of these apply: special or children's information; monitoring of staff or the public; biometrics; large-scale or new technology (including generative AI); automated decision-making with legal or similar effect; cross-border transfer; data matching; or any s.57 category. Otherwise record a short-form assessment.	IO, CL	5 working days (BP)	PO18	REG reg 4(1)(b); LAW s.57, s.71; BP
1.3 Lawful basis, purpose and minimality	Full or short PIIA.	Confirm the s.11 ground and, for special information, the s.27–s.33 authorisation. Confirm the purpose is specific and explicit (s.13). Strip out data fields that are not needed (s.10). Check further processing of existing data against s.15(2), considering the relationship between the purposes, the nature of the information, the consequences for the data subject, how it was collected, and contractual rights.	CL	Within the PIIA	PO07 updated	LAW s.9–s.11, s.13, s.15, s.26–s.35
1.4 Transparency	New collection or new purpose.	Draft or update the s.18 notice and, where consent is the ground, the consent wording and withdrawal route. For employees, issue the notice through HR and record acknowledgement.	CL, HR, MKT	Before go-live	PO08	LAW s.18



Step	Trigger	Organisational action	Owner	Deadline	Form	Authority
1.5 Security design	System or vendor involved.	ISO reviews the architecture: hosting location, encryption, identity and access, logging, retention and deletion, backup, penetration test for internet-facing systems. Vendor due diligence covers certifications, breach history, sub-operators and data location.	ISO, PROC	Before contract signature	PO10; PO11	LAW s.19, s.21
1.6 AI and automated decisions	The tool uses AI, profiling or automated scoring (for example CV screening, productivity analytics, chatbots, transcription or copilots).	Run the GBS AI compliance flow in parallel. Confirm whether staff or customer data will be used to train the vendor's models; block it unless the PIIA approves it. If a decision with legal consequences or substantial effect is based solely on automated processing, either fit the s.71(2) exceptions (contract with appropriate measures, or law or code) or put a human reviewer in the loop. Give the data subject the chance to make representations and enough information about the underlying logic.	IO, CL, ISO	Before go-live	PO19 AI addendum	LAW s.71(1)–(3), s.15, s.19, s.72; GBS AI compliance flow
1.7 Prior authorisation	Activity falls in a s.57(1) category and no code applies.	Notify the Regulator and apply for prior authorisation online before processing. Do not start until the Regulator has finished its investigation or told the organisation that no detailed investigation will be made. The Regulator must say within 4 weeks whether it will investigate in detail (s.58(3)), and a detailed investigation may not exceed 13 weeks (s.58(4)). If the Regulator misses either period, the organisation may presume a favourable decision and proceed (s.58(7)); record the dates. A statement that the processing is unlawful is treated as an enforcement notice (s.58(6)). Starting early is an offence (up to 12 months).	IO, CL	Before processing; allow 13 weeks in the project plan	PO16 application	LAW s.57(1)–(3), s.58(1)–(7), s.59, s.107(b); GN prior authorisation guidance (January 2024) paras 6–9
1.8 Cross-border	Data will leave South Africa.	Complete the s.72 assessment; add standard data-transfer terms to the operator contract; for health information, apply the 2026 health regulations.	CL	Before transfer	PO15	LAW s.72; REG health regs



Step	Trigger	Organisational action	Owner	Deadline	Form	Authority
1.9 Contract	Operator engaged.	Sign the operator agreement before any data is shared. Check that the vendor's standard terms do not override it.	PROC, CL	Before data shared	PO09	LAW s.20–s.21
1.10 Go-live sign-off	PIIA complete and controls implemented.	IO, or a DIO under delegation, signs off with residual risks accepted by the business owner at the right level. Update the inventory, PAIA manual (if categories change) and retention schedule.	IO, business owner	Before go-live	PO20 sign-off; PO06 updated	REG reg 4(1)(a)–(b); LAW s.17
1.11 Post-implementation review	90 days after go-live (BP).	Confirm the controls work as designed: access reviews, logs, deletion, notice display. Close or escalate findings.	IO, ISO	Go-live + 90 days (BP)	PO20 addendum	BP

Data-subject obligations at this stage. None. Data subjects receive the notice and, where consent is the ground, decide freely. They keep the right to object at any time to processing under s.11(1)(d)–(f) (s.11(3)(a)).

Hand-offs. Business owner → IO (screening). IO → ISO and CL (assessment). CL → IR (prior authorisation). PROC → OP (contract). IO → GBS AI compliance flow (AI tools). IO → website owner (manual and notice update).

Watch. The common failure is shadow procurement: staff sign up to free or low-cost cloud and AI tools with a credit card and upload customer or employee data. Block unsanctioned tools technically where possible, and make the screening form short enough that people actually use it.

05 / POPIA COMPLIANCE PROCESS

Phase 2 — Data-subject requests, objections and complaints

A request may arrive by any channel and be addressed to anyone in the organisation. The clock starts when the organisation receives it, not when the IO first reads it. Track 2A covers access, 2B correction and deletion, 2C objection and direct-marketing opt-out, and 2D

internal complaints. Requests and objections under POPIA are free of charge (amended regs 2–3). A PAIA request fee and access fees may apply only where the information is released under PAIA.

Track 2A — Access to personal information

Step	Trigger	Organisational action	Owner	Deadline	Form	Authority
2A.1 Recognise and route	Any person asks whether the organisation holds their information, or asks for a copy. This includes an employee asking HR for their file.	Forward to the IO or DIO the same day. Do not ask why the person wants it: the motive is irrelevant to a POPIA access request.	Any employee	Same day (BP)	PO21 log	LAW s.23(1); BP
2A.2 Log and acknowledge	Request received.	Log the date received, channel and scope. Acknowledge in writing with a reference number and the expected decision date.	DIO	2 working days (BP)	PO21	BP
2A.3 Verify identity	Requester not already authenticated.	Ask for adequate proof of identity, proportionate to the risk, before releasing anything. If a representative acts, ask for written authority. Never send records to an unverified email address.	DIO	Before release	PO22	LAW s.23(1) ("adequate proof of identity"); s.19
2A.4 Confirm free of charge	Request asks only whether information is held.	Confirm free of charge whether the organisation holds personal information about the requester.	DIO	Reasonable time; BP 10 days	PO25	LAW s.23(1)(a)
2A.5 Scope and search	Request asks for the record or a description.	Search all systems on the inventory, including email, HR, CRM, CCTV and backups if reasonably retrievable. Include the identity of third parties, or categories of third parties, who have had access. If the request is large, consider the s.57 PAIA extension now, not on day 29.	DIO, ISO, HR	By day 20 (BP)	Search log	LAW s.23(1)(b); PAIA s.57(1)

Step	Trigger	Organisational action	Owner	Deadline	Form	Authority
2A.6 Apply refusal grounds	Records contain third-party information, privileged material or commercial information.	Apply only the PAIA Chapter 4 Part 3 grounds (for example s.63 third-party privacy, s.64 commercial information, s.67 legal privilege, s.68 own commercial information). Sever and release the rest (PAIA s.59). If a third party must be notified under PAIA s.71, inform it within 21 days of receiving the request and allow it 21 days to make representations or consent (PAIA s.71(2)–(3)); diarise the decision date accordingly. Also check the PAIA s.7 exclusion where civil or criminal proceedings have already begun.	CL	By day 25 (BP)	Redaction schedule	LAW POPIA s.23(4); PAIA s.7, s.59, s.63–s.70, s.71
2A.7 Fees	Release under PAIA.	Issue a written fee estimate before doing the work and allow the requester to withdraw. Apply only the prescribed fees: request fee R140; search and preparation R145 per hour after the first hour, capped at R435; copies per tariff. If search and preparation will exceed six hours, require a deposit of one third, refundable if access is refused (PAIA s.54(2)–(4)).	DIO	With decision	PO24 PAIA Form 3	LAW POPIA s.23(3); PAIA s.54(1)–(7); REG PAIA Regulations 2021 Annexure B
2A.8 Decide and notify	Search and review complete.	Decide and notify in writing within 30 days of receipt. If access is refused, give reasons and tell the requester of the right to complain to the Regulator or apply to court. Silence by day 30 (or the extended date) is a deemed refusal. Tell the requester of the right to ask for correction (s.23(2)).	IO or DIO	Day 30; one extension of up to 30 days with written reasons before day 30	PO24; PO25	LAW PAIA s.56(1)–(3), s.57, s.58; POPIA s.23(2), s.25
2A.9 Release securely	Access granted and any fee paid.	Release in a reasonable manner and format, in a form that is generally understandable: an encrypted file, secure portal or collection in person. Record what was released.	DIO, ISO	Promptly after payment	PO21	LAW s.23(1)(b)(iii)–(iv); s.19



Track 2B — Correction, deletion and destruction

Step	Trigger	Organisational action	Owner	Deadline	Form	Authority
2B.1 Receive request	Data subject says information is inaccurate, irrelevant, excessive, out of date, incomplete, misleading or unlawfully obtained, or asks for deletion because retention is no longer authorised.	Log and acknowledge. Accept requests in any form substantially similar to Form 2 and by any channel. No charge.	DIO	Same day log; 2 working days acknowledgement (BP)	PO27	LAW s.24(1)(a)–(b); REG reg 3 and Form 2 as amended
2B.2 Assess	Logged.	Check the record and the s.14 retention position. Distinguish a factual error (correct it) from a contested opinion, such as a performance rating or disciplinary finding (attach the data subject's statement rather than rewrite it).	DIO, record owner	By day 15 (BP)	Assessment note	LAW s.24(2)(a)–(c)
2B.3 Act	Assessment complete.	Correct, destroy or delete as requested; or give the data subject credible evidence supporting the information; or, if no agreement is reached and the data subject asks, attach an indication to the record that a correction was requested but not made.	Record owner	As soon as reasonably practicable	PO27	LAW s.24(2)–(3)
2B.4 Inform recipients	The change affects a decision taken or to be taken about the data subject.	Where reasonably practicable, tell each person or body to whom the information was disclosed, for example payroll, a medical aid, a background-check agency or a reference recipient.	DIO	With 2B.3	Notification record	LAW s.24(3)

Step	Trigger	Organisational action	Owner	Deadline	Form	Authority
2B.5 Notify outcome	Action taken.	Notify the data subject in writing of the action taken. The amended regulation requires this within 30 days of "receiving the outcome of the request". Read it as 30 days from receipt of the request to avoid argument (see drafting issue 2).	DIO	Within 30 days (REG); BP within 30 days of receipt	PO27 outcome	LAW s.24(4); REG reg 3 as amended
2B.6 Legal hold check	Deletion requested of records under a hold or needed as evidence.	Restrict processing instead of deleting, and tell the data subject why.	CL	Before deletion	PO43	LAW s.14(6)

Track 2C — Objection and direct-marketing opt-out

Step	Trigger	Organisational action	Owner	Deadline	Form	Authority
2C.1 Receive objection	Data subject objects to processing based on public law duty, legitimate interest of the data subject, or legitimate interest of the organisation or a third party (s.11(1)(d)–(f)), or objects to direct marketing.	Accept on a form substantially similar to Form 1 or by any channel, including telephone (recorded) and WhatsApp, during office hours, free of charge.	Any channel owner → DIO	Same day log (BP)	PO26	LAW s.11(3)(a)–(b); REG reg 2 and Form 1 as amended
2C.2 Direct marketing	Objection or opt-out relates to marketing.	Stop all direct marketing to that person on every channel. Add them to the suppression list across all systems and operators (call centres, agencies).	MKT	2 working days (BP); never send another message	PO14	LAW s.11(3)(b), s.11(4), s.69(4)(b)

Step	Trigger	Organisational action	Owner	Deadline	Form	Authority
2C.3 Other objection	Objection to s.11(1)(d)–(f) processing.	Assess whether the objection gives reasonable grounds relating to the data subject's particular situation, unless legislation provides for the processing. If it does, stop the processing (s.11(4)). If not, explain in writing why processing continues (for example, a legal obligation under s.11(1)(c) applies) and give the right to complain to the Regulator.	IO, CL	30 days (BP)	PO26 response	LAW s.11(3)(a), s.11(4)

Track 2D — Internal privacy complaints

Step	Trigger	Organisational action	Owner	Deadline	Form	Authority
2D.1 Receive	A data subject (customer, employee or applicant) complains about how their information was handled.	Log; acknowledge; check whether the complaint also reveals a security compromise (go to Phase 3) or a protected disclosure (GBS PDA flow).	DIO	Acknowledge in 2 working days (BP)	PO28	LAW s.55(1)(b); BP
2D.2 Investigate	Complaint logged.	Gather facts from the record owner, decide and remedy. Offer a written apology where appropriate, but note that a court has held that a public apology is not a competent POPIA remedy (*Munetsi v Madhuyu*, WCC 2024).	DIO, CL	30 days (BP)	PO28	BP; CL *Munetsi v Madhuyu* (WCC 2024)
2D.3 Close and signpost	Decision made.	Give a written outcome and tell the complainant of the right to complain to the Regulator on Form 5.	DIO	With 2D.2	PO28	LAW s.74; REG reg 7 and Form 5

Data-subject obligations at this stage. Give adequate proof of identity (s.23(1)). Use a form substantially similar to the prescribed forms, or another permitted channel (amended regs 2–3). Pay any prescribed PAIA fee where access is given under PAIA (PAIA s.54).



State reasonable grounds for an objection under s.11(3)(a). Requests must relate to the requester's own personal information, or be made with authority.

Hand-offs. Any employee → DIO (same day). DIO → ISO and HR (search). DIO → CL (refusal grounds). DIO → MKT (suppression). DIO → payroll, medical aid or vetting agency (s.24(3) notices). DIO → IO (escalations and refusals).

Watch. Employee access requests often arrive in the middle of a disciplinary or CCMA dispute. Once civil or criminal proceedings have begun, PAIA does not apply to a request for records for those proceedings if production is otherwise provided for by law (PAIA s.7). Before the proceedings begin, the request must be answered normally. Get CL to decide which applies on day 1, not day 29.

Phase 3 — Security compromise (s.22) incident response

A security compromise is any case where there are reasonable grounds to believe that personal information has been accessed or acquired by an unauthorised person (s.22(1)). The trigger is reasonable grounds to believe, not proof. Ransomware, a misdirected email, a lost laptop, a staff member sharing records on WhatsApp and an operator's compromise all qualify. The Regulator expects notification through its eServices portal, which it made mandatory for compromise reports from 1 April 2025 (media statement of 7 April 2025). It reported more than 8 000 notifications to date, and more than 1 220 since its 1 April 2026 briefing (September 2026).

Step	Trigger	Organisational action	Owner	Deadline	Form	Authority
3.1 Detect and report	Alert, user report, operator notice, ransom note, media report or Regulator query.	Every employee reports suspected incidents to the IT service desk or IO immediately. Operators must notify immediately (s.21(2)). Log the time of first knowledge. This is hour 0.	All staff, OP	Immediately	PO29	LAW s.21(2), s.22(1); BP
3.2 Activate	Incident logged.	ISO convenes the incident team (ISO, IO, CL, Communications, HR if staff are involved). Open a privileged incident file under CL's instruction where litigation is likely.	ISO, CL	Within 4 hours (BP)	PO30	BP

Step	Trigger	Organisational action	Owner	Deadline	Form	Authority
3.3 Contain and preserve	Team convened.	Isolate affected systems, reset credentials, revoke access, recall emails, and remote-wipe lost devices. Preserve logs and images for forensics and SAPS. Do not pay a ransom without CL and Board decision and sanctions screening.	ISO	Immediately; continuous	PO33 evidence log	LAW s.19(1)–(2), s.22(2) ("restore the integrity")
3.4 Assess	Initial containment done.	Determine what personal information, whose, how many data subjects, which categories (special, children's, financial, account numbers, ID numbers), whether encrypted, whether exfiltration is confirmed, and the likely consequences. Record the s.22(1) decision: reasonable grounds yes or no, with reasons.	ISO, IO	Within 24 hours (BP)	PO30 decision log	LAW s.22(1), (5)(a)
3.5 Law enforcement	Criminal conduct suspected (hacking, extortion, insider theft).	Open a SAPS case and keep the CAS number. Ask SAPS in writing whether notification would impede the investigation. Only a public body responsible for preventing, detecting or investigating offences, or the Regulator, can justify delaying notification to data subjects. Note that the Cybercrimes Act s.54 reporting duty for ECSPs and financial institutions (72 hours where feasible) is not yet in operation (MJK, reviewed 1 July 2026; re-check at each horizon scan).	CL	Within 72 hours (BP)	PO33	LAW s.22(3); Cybercrimes Act 19 of 2020 ss.2–5 (offences, in force 1 December 2021), s.54 (DRAFT, not in operation)
3.6 Notify the Regulator	Reasonable grounds confirmed.	IO or a registered DIO submits the notification on the eServices portal. Include the responsible party and IO details, date of the compromise and of discovery, reason for any delay, description and type of compromise, categories of information, number of data subjects, possible consequences, measures taken and how data subjects were or will be notified. Do not wait for forensics to finish: notify, then supplement.	IO	As soon as reasonably possible; BP within 72 hours of 3.4	PO31	LAW s.22(1)–(2); GN security compromise guidelines (August 2022) and SCN1 content; eServices reporting since April 2025



Step	Trigger	Organisational action	Owner	Deadline	Form	Authority
3.7 Notify data subjects	Data subjects identifiable and no s.22(3) delay.	Notify in writing by mail to the last known address, email, a prominent website notice, news media, or as the Regulator directs. Give enough information to let them take protective measures: possible consequences; measures taken or intended; recommendations to mitigate (for example change passwords, watch for fraud, contact the bank); and the identity of the unauthorised person, if known.	IO, Comms	As soon as reasonably possible; with or soon after 3.6	PO32	LAW s.22(1), (4)–(5); TransUnion and Lancet enforcement (s.22)
3.8 Regulator directions	Regulator directs publicity or asks for more information.	Comply with any direction to publicise the compromise to protect data subjects. Answer information requests within the period stated.	IO	As directed	PO35	LAW s.22(6); s.90
3.9 Third parties	Compromise involves an operator, joint processor, bank or medical aid.	Coordinate notices so data subjects receive one clear message. Where the organisation is itself an operator for a client, notify the client immediately and do not notify data subjects directly unless the contract says so.	CL, PROC	Same day as 3.4 (BP)	PO35	LAW s.21(2)
3.10 Staff involvement	An employee caused or contributed to the compromise.	Refer to HR for investigation under the GBS Misconduct flow. Distinguish negligence (training and corrective action) from deliberate disclosure (discipline). Keep the employee's own personal information confidential.	HR, LM	Within 7 days (BP)	HR referral	LRA s.188; Code of Good Practice: Dismissal, 2025 (GN 3470, GG 53294); CJC TVET enforcement notice (action against employee within 60 days)
3.11 Remediate	Containment holds.	Fix the root cause: patching, MFA, licence renewal, operator replacement or contract change. Update the risk register.	ISO	30 days (BP)	PO34	LAW s.19(2)(d)
3.12 Post-incident review	Incident closed.	Lessons learnt; Board report; update the incident plan, training and Phase 0 controls. Keep the file for at least 5 years (BP).	IO, ISO	Closure + 30 days (BP)	PO34	LAW s.19(2)(d); BP



Data-subject obligations at this stage. None by law. Data subjects are expected to act on the recommendations in the notice (change passwords, alert banks). Some may complain to the Regulator (s.74) or sue for damages (s.99, see P5).

Hand-offs. Staff and OP → ISO and IO (immediate). ISO → IO (assessment). IO → IR (eServices). IO → data subjects (notice). CL → SAPS (case). HR → Misconduct flow. IO → BOARD (crisis decisions and closure report).

Watch. The two most common enforcement findings are late or missing notification and repeated incidents with no notification at all (Lancet Laboratories, fined R100 000 and paid). An accidental cause does not remove the duty to notify (CJC TVET enforcement notice, 2026). If the organisation decides that a near-miss is not notifiable, record why. That record is the evidence in an assessment.

07 / POPIA COMPLIANCE PROCESS

Phase 4 — Information Regulator interactions

The Regulator becomes involved through a complaint (s.74), its own initiative (s.76(3)), an assessment (s.89), a security compromise notification, or a prior authorisation application. Most matters close at the pre-investigation or settlement stage. The formal route is: pre-investigation (s.79), settlement (s.80), investigation (s.81), referral to the Enforcement Committee (s.92), enforcement notice (s.95), appeal (s.97), and an infringement notice with an administrative fine (s.109). Failing to comply with an enforcement notice is an offence (s.103(1)).

Step	Trigger	Organisational action	Owner	Deadline	Form	Authority
4.1 Receive and log	Any letter, email or eServices message from the Regulator: complaint notification, request for information, assessment notice, warrant or prior authorisation query.	Log in the Regulator correspondence register. Diarise the response date stated. Notify CL and the Board chair if the matter is an enforcement or assessment step. Never ignore a Regulator letter: several fines followed ignored enforcement notices (DoJ, FT Rams, Blouberg).	IO	Same day	PO35	LAW s.55(1)(c); BP

Data-subject and complainant rights at this stage. Complain to the Regulator (s.74); ask that their identity is not disclosed, with reasons (amended reg 7.11); appeal the outcome of an investigation within 180 days (s.97(2)); sue for damages (s.99).

Hand-offs. IR → IO (all correspondence). IO → CL (legal response). CL → BOARD (appeal or payment decision). IO → ISO, HR, MKT (implementation of orders). IO → IR (compliance proof).

Watch. The Regulator states its own position strongly, but not every notice survives court review: the matric results notices were set aside in December 2025. Comply, or appeal within 30 days; never do neither. An organisation that lets the period run out loses the appeal and still faces the s.103(1) offence.

Phase 5 — Monitoring, audit, reporting and annual review

Phase 5 runs on a calendar. It closes every route from Phases 1–4 and feeds lessons back into Phase 0.

Step	Trigger	Organisational action	Owner	Deadline	Form	Authority
5.1 Monthly metrics	Month end.	Requests received and closed on time; objections; incidents; notifications; vendor contracts outstanding; training completion; PIIAs open.	IO	Monthly (BP)	Dashboard	BP
5.2 PAIA annual report	1 April each year.	The head of the private body or a DIO submits the PAIA report on requests received and processed for the prior year on the eServices portal. Only registered officers can submit.	IO, DIO	1 April – 30 June	PO38 submission proof	LAW PAIA s.83(4); GN Regulator PAIA annual report notice (window 1 April – 30 June)
5.3 Registration and manual check	Annually and on change of head or DIO.	Confirm the eServices registration details; update the PAIA manual and website.	IO	Annually; change + 30 days (BP)	PO03; PO05	LAW s.55(2); PAIA s.51(2); GN IO guidance note para 11.1

Step	Trigger	Organisational action	Owner	Deadline	Form	Authority
5.4 Inventory refresh	Annually.	Each business owner re-confirms their processing activities, purposes, lawful grounds, retention and operators.	CL	Annually (BP)	PO06	LAW s.17
5.5 Operator assurance	Annually.	Obtain security attestations, certificates or audit reports from high-risk operators; review sub-operators and data locations.	PROC, ISO	Annually (BP)	PO10	LAW s.21
5.6 Security testing	Annually, or on major change.	Penetration test, access review, backup restoration test, phishing simulation, incident tabletop.	ISO	Annually (BP)	PO11	LAW s.19(2)(c)–(d)
5.7 Retention run	Quarterly.	Destroy or de-identify records past their retention period, unless they are under a legal hold. Keep destruction certificates.	Record owners	Quarterly (BP)	PO12	LAW s.14(4)–(5)
5.8 Internal audit	Annual audit plan.	Audit against the POPIA checklist: governance, notices, lawful grounds, special information, DSR timeliness, incidents, operators, cross-border, direct marketing, training.	IA	Annually (BP)	PO39	LAW s.8; BP
5.9 Annual privacy report	Financial year end.	IO reports to the Board: compliance status, incidents, Regulator matters, audit results, regulatory change (for example the 2026 health regulations, the National Opt-Out Registry, any POPIA amendment bill), and the next year's plan.	IO, BOARD	Annually (BP)	PO37	LAW s.8, s.55(1)(d)
5.10 Regulatory horizon scan	Quarterly.	Track new regulations, guidance notes (a PIIA guidance note is planned), codes of conduct (for example the gated-access code), enforcement decisions and case law. Update this flow.	CL	Quarterly (BP)	Change log	BP

Data-subject obligations at this stage. None.

Hand-offs. Record owners → IO (attestations). IA → BOARD (audit). IO → IR (PAIA report). IO → BOARD (annual report). CL → all (regulatory change).

Watch. The PAIA annual report for private bodies is described on the Regulator's site as "requested", but the Regulator now chases non-filers publicly and the IO guidance note links it to s.83(4). File it every year. It costs little and avoids a visible compliance gap.

09 / POPIA COMPLIANCE PROCESS

Employment track — employee and applicant information (E)

Employers process more special personal information about employees than about almost anyone else: health records, biometrics, race (for employment equity), trade union membership and criminal records. The employment track applies Phases 0–3 to the employment lifecycle. It links to the GBS Resourcing (Recruitment and Selection), Performance Management, Incapacity, Misconduct, Operational Requirements, COIDA, OHSA and Off-Boarding flows.

Step	Trigger	Organisational action	Owner	Deadline	Form	Authority
E.1 Recruitment notice	Vacancy advertised; CV received.	Give applicants a s.18 notice. Collect only what the selection needs. Keep unsuccessful applicants' CVs only for a stated period (BP 12 months, or longer with consent for a talent pool). Recruitment agencies are separate responsible parties or operators: define which in the contract.	HR	At application	PO08 applicant notice	LAW s.10, s.14, s.18, s.20–s.21; GBS Resourcing flow
E.2 Screening and AI	CV screening or assessment tools used.	Run Phase 1 (PIIA and AI addendum). No candidate is rejected solely by an automated decision without a human review route. Psychological tests must be scientifically valid and reliable, fairly applied and not biased.	HR, IO	Before use	PO18; PO19	LAW POPIA s.71; EEA s.8; GBS AI compliance flow

Step	Trigger	Organisational action	Owner	Deadline	Form	Authority
E.3 Criminal, credit and qualification checks	Shortlisted candidate.	Check only where inherent to the job. Obtain written consent and use an accredited vetting operator under a s.21 contract. Criminal information is special personal information; process it only under s.27 or s.33 and labour legislation rules. Credit reports for employment are limited to positions requiring honesty in dealing with cash or finances, with the candidate's written consent and a job description that shows this (NCA Regulations reg 18(4)(g), reg 19(12)). Prior authorisation applies only if the organisation processes criminal information on behalf of third parties (s.57(1)(b)), which is the vetting agency's issue, not the employer's.	HR	Before offer	PO41 consent	LAW s.26, s.27, s.33, s.57(1)(b); NCA Regulations reg 18(4)(g), reg 19(12); CJC TVET enforcement notice, 22 May 2026 (vetting reports with criminal-record details circulated to staff: s.15, s.19, s.22)
E.4 Onboarding	Offer accepted.	Issue the employee privacy notice covering HR, payroll, benefits, medical aid, pension, EE reporting, monitoring and CCTV, biometrics, cross-border HR systems, and retention. Sign confidentiality undertaking. Record the ground for each category, usually contract or legal obligation, not consent.	HR	Day 1	PO08; PO17	LAW s.11(1)(b)–(c), s.18
E.5 Race and EE data	EE reporting cycle.	Race data may be processed where essential to identify data subjects or to comply with laws and measures designed to protect or advance disadvantaged persons (s.29). Disability data is health information: process it under s.32(1)(f)(i) for EE compliance, or with consent, subject to the duty of confidentiality (s.32(2)) and the 2026 health regulations. Keep EE data in restricted access.	HR	Per EE cycle	PO13; PO42	LAW s.29(a)–(b), s.32(1)(f)(i), s.32(2); REG GN 7198 (2026); EEA s.19, s.21



Step	Trigger	Organisational action	Owner	Deadline	Form	Authority
E.6 Health information	Sick notes, medical certificates, incapacity, medical surveillance, wellness, COIDA.	Treat as special personal information. Process under s.32(1)(f) (proper implementation of laws, pension regulations, collective agreements, or reintegration and support for workers entitled to benefits linked to sickness or incapacity) or with consent. Apply the 2026 health regulations: every person with access must be bound by a duty of confidentiality (by law, office, employment, profession or written agreement; obtain a signed PO42 undertaking as evidence, BP); restricted role-based access; secure storage and disposal; s.72 controls for offshore HR systems. Sick notes and wellness data are not excluded.	HR, OHS, ISO	Now; on each record	PO42	LAW s.26, s.27, s.32(1)(f), s.32(2); REG GN 7198 (6 March 2026); EEA s.7; BCEA s.23; GBS Incapacity, COIDA and OHSA flows
E.7 Trade union data	Union deductions and recognition.	Process union membership only as needed for LRA s.13 stop-order deductions and organisational rights; restrict access.	HR, payroll	Ongoing	PO13	LAW s.26, s.27(1)(b); LRA s.13 (s.30 applies to unions themselves, not employers)
E.8 Biometrics	Fingerprint or facial access control or time and attendance.	Run a PIIA. Biometrics are special personal information. Offer a non-biometric alternative where practicable, store templates rather than images, encrypt them, and delete them on exit. Record the s.27 authorisation (consent or another ground).	ISO, HR	Before deployment	PO18; PO40	LAW s.1 "biometrics", s.26, s.27, s.33
E.9 Monitoring	Email, internet, device, call recording, GPS, CCTV or productivity monitoring.	Adopt an electronic communications and monitoring policy; inform employees in advance; tie the monitoring to a stated purpose; limit access to monitoring results. Interception of communications in the course of business must meet RICA (system controller consent or reasonable efforts to inform). Post CCTV signage; no cameras in private areas; covert monitoring only on specific legal advice.	HR, ISO, CL	Before monitoring	PO40	LAW POPIA s.13, s.15, s.18; RICA 70 of 2002 s.6 (verify); Constitution s.14

Step	Trigger	Organisational action	Owner	Deadline	Form	Authority
E.10 Discipline and investigations	Misconduct alleged.	Use personal information for an investigation only if compatible with the original purpose (s.15) or under a legitimate interest ground. Share findings on a need-to-know basis. Witness statements contain third-party information: protect it in any access request.	HR, LM	Per Misconduct flow	Investigation file	LAW s.11(1)(f), s.15; GBS Misconduct flow; PDA flow for disclosures
E.11 References and third-party requests	A prospective employer, bank or landlord asks for information about an employee.	Disclose only with the employee's consent or another lawful ground. Limit to what is asked and verifiable. Keep a record.	HR	Per request	Disclosure record	LAW s.11, s.15
E.12 Exit and retention	Resignation, dismissal, retrenchment or retirement.	Remove access on the last day; recover devices; delete biometrics; retain records per the retention schedule (BCEA s.31: 3 years; tax records 5 years under the Tax Administration Act; others per law). Issue the certificate of service.	HR, ISO	Last day; retention per schedule	PO12	LAW s.14; BCEA s.31, s.42; Tax Administration Act s.29 (verify); GBS Off-Boarding flow

Employee obligations. Keep personal information they handle confidential and use it only for work purposes; report incidents immediately; follow the monitoring and acceptable-use policy; give accurate information and update it. A former employee who takes client lists can be interdicted (*Zulu Nyala Game Ranch v Beukes*, KZD 2025, where the court applied s.20 to an employee).

Watch. Do not rely on employee consent as a blanket ground. Consent can be withdrawn at any time and, in an employment relationship, may not be voluntary. Use the specific ground for each category, and keep consent for genuinely optional processing such as wellness programmes or a talent pool.

Parallel track — events that can arise at any time

These events are not tied to a phase. Each has its own trigger and owner, and each can start a Phase 2, 3 or 4 route.



Event	Who	Trigger	Organisational action	Deadline	Form	Authority
P1 Operator compromise	OP, ISO, IO	Vendor reports a compromise affecting the organisation's data.	Treat as Phase 3 hour 0 for the organisation. The organisation, not the operator, notifies the Regulator and data subjects. Review the contract and the vendor's root-cause report.	Immediately	PO29	LAW s.21(2), s.22
P2 Law-enforcement or court request	CL	SAPS subpoena (Criminal Procedure Act s.205), court order or statutory body request.	Verify the legal authority; disclose only what is required; record the disclosure. POPIA allows processing to comply with an obligation imposed by law.	Per order	Disclosure record	LAW s.11(1)(c), s.15(3)(c)
P3 Litigation hold	CL	Litigation, CCMA dispute, investigation or Regulator matter is reasonably anticipated.	Issue a hold notice and suspend destruction of the relevant records. Lift the hold when the matter ends.	Same day (BP)	PO43	LAW s.14(1)(a), s.14(6)
P4 Civil damages claim	CL, BOARD	Data subject or Regulator (at their request) sues for damages for interference with personal information.	Notify insurers. The claim lies whether or not there was intent or negligence; the available defences are limited (s.99(2)). Courts may award patrimonial and non-patrimonial damages, aggravated damages and costs.	Per court rules	Litigation file	LAW s.99
P5 Third-party PAIA request	IO, CL	A third party requests records containing employees' or customers' personal information.	Apply PAIA s.63 (mandatory protection of third-party privacy) and s.71 third-party notification; consider the public interest override (s.70).	30 days (PAIA s.56)	PO24	LAW PAIA s.63, s.70, s.71; CL *Arena Holdings v SARS* [2023] ZACC 13 (PAIA and public interest)
P6 Protected disclosure overlap	IO, DO	A whistle-blower report includes personal information, or a privacy breach is reported as a disclosure.	Run the GBS PDA flow; protect the discloser's identity. Personal information in the disclosure is processed under a legal obligation or legitimate interest.	Per PDA flow	PDA forms	LAW PDA 26 of 2000; POPIA s.11(1)(c), (f); REG reg 7.10

Event	Who	Trigger	Organisational action	Deadline	Form	Authority
P7 Merger, sale or group transfer	CL, IO	A business sale, transfer under LRA s.197, or group reorganisation.	Run a PIIA on data transfer; disclose the minimum in due diligence under NDA; update notices; transfer HR records as the new employer needs them.	Before transfer	PO18	LAW s.11, s.15, s.18; LRA s.197
P8 Media or social-media exposure	Comms, IO	Personal information appears on social media or in the press, or an employee posts customer or colleague information.	Request take-down; assess under Phase 3; discipline where appropriate. Publishing a person's information on social media without a lawful ground breaches s.11 (*Munetsi v Madhuyu*, WCC 2024). Information already made public is still personal information, but its processing may be justified (*Smuts v Botha* [2022] ZASCA 3).	Same day (BP)	PO29	LAW s.11, s.22; CL as cited
P9 Children's information	IO, MKT, HR	Processing of information about a child under 18: learners, bursaries for employees' children, school programmes, marketing to minors, CSI.	Obtain prior consent of a competent person (usually a parent or guardian) or apply another s.35(1) ground. Never send direct marketing to a child without that consent. Sending children's information offshore without adequate protection needs prior authorisation.	Before processing	PO13	LAW s.1 "child", s.34, s.35, s.57(1)(d)
P10 Deceased data subject	IO, HR	Request from the estate of a deceased employee or customer.	Deal with the executor or next of kin; verify authority; release under PAIA rules on records about deceased persons.	30 days	PO24	LAW PAIA s.63(2)(e)

Obligations and conduct of data subjects

Data subjects have rights, not duties, under POPIA. The exercise of each right still depends on certain steps, which the organisation may require but must not use to obstruct.

Requirement on the data subject	When	Consequence if not met	Authority
Provide adequate proof of identity	Access request	Organisation may decline until identity is verified	POPIA s.23(1)
Use a form substantially similar to the prescribed form, or a permitted channel	Objection, correction, deletion, direct-marketing consent	Request may be clarified, but must not be rejected for form alone	REG regs 2, 3, 6 as amended
Pay prescribed PAIA fees	Access under PAIA	Release may wait for payment; POPIA confirmation stays free	PAIA s.54; POPIA s.23(1)(a), (3)
Give reasonable grounds relating to their particular situation	Objection under s.11(3)(a)	Processing may continue where legislation provides for it	POPIA s.11(3)(a)
Make requests about their own information, or with authority	All requests	Third-party information is protected under PAIA s.63	POPIA s.23; PAIA s.63
Give accurate information	Collection	Organisation may rely on information provided (s.16)	POPIA s.16
Lodge complaints in writing, with prescribed details	Complaint to the Regulator	Regulator helps the complainant put it in writing	POPIA s.74; REG reg 7
Appeal within time	Investigation outcome	Late appeal may be barred	POPIA s.97(2): 180 days



Rights the organisation must not obstruct. To be notified at collection and of a security compromise (s.5(a), s.18, s.22); to establish whether information is held and to request access (s.5(b), s.23); to request correction, destruction or deletion (s.5(c), s.24); to object on reasonable grounds and to direct marketing (s.5(d)–(e), s.11(3)); not to receive unsolicited electronic direct marketing except under s.69 (s.5(f), s.69); not to be subject to solely automated decisions with legal effect (s.5(g), s.71); to complain to the Regulator (s.5(h), s.74); and to sue for damages (s.5(i), s.99).



Hand-offs, RACI and interfaces register

RACI by phase

R = responsible (does the work); A = accountable (signs off); C = consulted; I = informed.

Activity	BOARD	IO	DIO	CL	HR	ISO	MKT	PROC	OP
0.1–0.3 IO, DIOs, registration	A	R	C	C	I	–	–	–	–
0.4 Policy and framework	A	R	C	C	C	C	C	I	–
0.5 PAIA manual	I	A	R	C	C	C	I	–	–
0.6–0.7 Inventory and lawful bases	I	A	C	R	C	C	C	C	C
0.9 Operator contracts	–	A	I	R	I	C	I	R	C
0.10 Security safeguards	I	C	–	C	I	A/R	–	C	R
0.13 Direct marketing	–	A	I	C	–	C	R	–	C
Phase 1 PIIA and go-live	I	A	R	C	C	R	C	C	C
Phase 2 requests	–	A	R	C	C	C	C	–	C
Phase 3 compromise	I/C	A	R	R	C	R	I	C	R
Phase 4 Regulator	A (appeal, fine)	R	C	R	C	C	C	–	–
Phase 5 review and reporting	A	R	R	C	C	C	C	C	C

Activity	BOARD	IO	DIO	CL	HR	ISO	MKT	PROC	OP
Track E employee data	I	A	C	C	R	C	–	–	C

Interfaces register

Every hand-off carries a confidentiality risk. Send the minimum, use secure channels, and log what was sent, to whom and when.

Party or system	Trigger	What is handed over	When	Step	Authority
Information Regulator — eServices	IO or DIO appointed or changed	Registration particulars	Before duties; on change	0.3, 5.3	POPIA s.55(2)
Information Regulator — eServices	Security compromise	Compromise notification and supplements	As soon as reasonably possible	3.6	POPIA s.22
Information Regulator — eServices	1 April – 30 June	PAIA s.83(4) annual report	Annually	5.2	PAIA s.83(4)
Information Regulator — online application	s.57 processing	Prior authorisation application	Before processing	1.7	POPIA s.58
Information Regulator — Enforcement Committee	Referral	Submissions and evidence	Per directions	4.7	POPIA s.92–s.94
High Court	Disputed notice	Appeal papers	30 days	4.9	POPIA s.97
SAPS	Criminal compromise	Case report, evidence	BP 72 hours	3.5	Cybercrimes Act; POPIA s.22(3)
Data subjects	Compromise	s.22 notice	As soon as reasonably possible	3.7	POPIA s.22(4)–(5)
Data subjects	Request decision	Outcome notice, records	30 days	2A.8, 2B.5	PAIA s.56; REG reg 3



Party or system	Trigger	What is handed over	When	Step	Authority
Operators	Contract; incident	Instructions; incident coordination	Before processing; immediately	0.9, 3.9	POPIA s.20–s.21
National Consumer Commission — Opt-Out Registry	Direct marketing	Marketer registration; monthly list screening	By December 2026; monthly	0.13	CPA s.11; CPA Amendment Regulations 2026
GBS AI compliance flow	AI tool or automated decision	PIIA, AI addendum	Before go-live	1.6, E.2	POPIA s.71
GBS Misconduct flow	Staff caused compromise or misused data	Incident facts	BP 7 days	3.10, E.10	LRA s.188; Code of Good Practice: Dismissal, 2025 (GN 3470, GG 53294)
GBS PDA flow	Disclosure involves personal information	Referral	Same day	P6	PDA
GBS CPA flow	Consumer direct marketing; consumer complaint	Suppression lists; complaint	Ongoing	0.13	CPA s.11
GBS Resourcing, Incapacity, COIDA, OHSA, Off-Boarding flows	Employee lifecycle events	Health, vetting and HR records under track E	Per flow	E.1–E.12	POPIA s.26–s.33; health regs 2026
Insurers (cyber, D&O)	Incident or claim	Notice per policy	Per policy (often 24–72 hours)	3.2, P4	Contract

Forms register

Code prefix PO. Templates are GBS working documents; prescribed statutory forms are named where they apply.



Code	Form	Phase / step	Purpose	Basis
PO01	IO authorisation letter	0.1	Head authorises IO in writing	GN IO guidance note Annexure C
PO02	DIO designation and delegation letter	0.2	Written designation and delegation	POPIA s.56; GN paras 7–8
PO03	eServices registration confirmation	0.3, 5.3	Proof of registration	POPIA s.55(2)
PO04	POPIA policy and privacy governance charter	0.4	Framework, roles, PSC	POPIA s.8; reg 4(1)(a)
PO05	PAIA manual	0.5, 5.3	s.51 manual	PAIA s.51
PO06	Personal information inventory and record of processing	0.6, 1.10, 5.4	Map of processing	POPIA s.17
PO07	Lawful basis and purpose register (with legitimate-interest notes)	0.7, 1.3	Justification per activity	POPIA s.11, s.13, s.15
PO08	Privacy notice set (customer, website and cookie, applicant, employee, visitor and CCTV, supplier)	0.8, 1.4, E.1, E.4	s.18 notification	POPIA s.18
PO09	Operator agreement / data processing addendum	0.9, 1.9	Written operator contract	POPIA s.20–s.21
PO10	Vendor privacy and security due-diligence questionnaire	0.9, 1.5, 5.5	Operator vetting and assurance	POPIA s.19, s.21
PO11	Information security policy and control matrix	0.10, 5.6	Safeguards and testing	POPIA s.19
PO12	Retention and destruction schedule; destruction certificate	0.11, 5.7, E.12	s.14 compliance	POPIA s.14
PO13	Special personal information and children register	0.12, E.5, E.7, P9	Authorisation per category	POPIA s.26–s.35
PO14	Direct marketing consent record (Form 4 equivalent) and suppression list	0.13, 2C.2	Consent and opt-outs	POPIA s.69; reg 6, Form 4
PO15	Cross-border transfer assessment	0.14, 1.8	s.72 basis	POPIA s.72



Code	Form	Phase / step	Purpose	Basis
PO16	Prior authorisation screening and application	0.15, 1.7	s.57–s.58	POPIA s.57–s.58
PO17	Training record and confidentiality undertaking	0.19, E.4	Awareness and confidentiality	reg 4(1)(e)
PO18	Personal information impact assessment (screening and full)	1.1–1.3, E.2, E.8, P7	Risk assessment	reg 4(1)(b)
PO19	AI tool privacy addendum	1.6, E.2	AI and automated decisions	POPIA s.71; GBS AI flow
PO20	Go-live privacy sign-off and post-implementation review	1.10–1.11	Approval and check	reg 4(1)
PO21	Data-subject request log	0.17, 2A–2C	Tracking and timeliness	POPIA s.23–s.24
PO22	Identity verification checklist	2A.3	Adequate proof of identity	POPIA s.23(1)
PO23	PAIA Form 2 (request for access to record), as received	2A	Statutory request form	PAIA Regulations 2021, reg 7
PO24	PAIA Form 3 (outcome of request and fees payable)	2A.7–2A.8, P5, P10	Decision and fees	PAIA Regulations 2021, reg 8
PO25	POPIA confirmation and access response letter	2A.4, 2A.8	s.23 response	POPIA s.23
PO26	Objection (POPIA Form 1) and response	2C	s.11(3)	reg 2, Form 1
PO27	Correction or deletion request (POPIA Form 2) and outcome notice	2B	s.24	reg 3, Form 2
PO28	Internal privacy complaint record	2D, 4.2	Complaint handling	POPIA s.55(1)
PO29	Incident first report	3.1, P1, P8	Hour-0 record	POPIA s.22
PO30	Incident assessment, severity matrix and decision log	3.2–3.4	Reasonable-grounds decision	POPIA s.22(1)
PO31	Regulator compromise notification (eServices content; SCN1 fields)	3.6	Notification	POPIA s.22; GN

Code	Form	Phase / step	Purpose	Basis
PO32	Data-subject compromise notice	3.7	Notification	POPIA s.22(4)–(5)
PO33	SAPS report and evidence log	3.3, 3.5	Criminal matters	Cybercrimes Act
PO34	Post-incident review	3.11–3.12	Lessons learnt	POPIA s.19(2)(d)
PO35	Regulator correspondence register and response pack	4.1–4.4, 3.8	Regulator dealings	POPIA Ch. 10
PO36	Enforcement, information and infringement notice response and decision memo	4.5, 4.8–4.11	Comply, appeal or pay	POPIA s.90, s.95, s.97, s.109
PO37	Board privacy report	0.20, 5.9	Accountability	POPIA s.8
PO38	PAIA s.83(4) annual report submission proof	5.2	Annual reporting	PAIA s.83(4)
PO39	POPIA compliance audit checklist	4.6, 5.8	Audit and assessment pack	POPIA s.8, s.89
PO40	Employee monitoring, CCTV and biometrics notice and acknowledgement	E.8, E.9	Transparency for monitoring	POPIA s.18, s.26; RICA
PO41	Background, criminal and credit check consent	E.3	Vetting	POPIA s.11, s.27, s.33
PO42	Health information confidentiality undertaking	0.12, E.6	Duty of confidentiality	POPIA s.32(2); health regs 2026
PO43	Legal hold notice	2B.6, P3	Suspend destruction	POPIA s.14

Timeline calendar and offences register

Event clocks (calendar days unless stated)

When	Event	Source	Type
Before duties start	IO and DIOs registered	POPIA s.55(2)	LAW
Before processing	Prior authorisation granted or Regulator says no detailed investigation	POPIA s.58(2)	LAW
Within 4 weeks of notification	Regulator indicates whether it will investigate a s.57 activity in detail	POPIA s.58(3); GN prior authorisation para 7.1.2	LAW
Within 13 weeks	Regulator completes detailed prior authorisation investigation; if either period is missed, a favourable decision may be presumed (s.58(7))	POPIA s.58(4), s.58(7); GN prior authorisation para 6.2.1	LAW
Request + 2 working days	Acknowledge request or objection	Internal	BP
Request + 30 days	PAIA access decision	PAIA s.56(1)	LAW
Day 30 + up to 30	One extension, notified before day 30	PAIA s.57	LAW
30 days	Notify outcome of correction or deletion request	REG reg 3 as amended	REG
Hour 0	First knowledge of possible compromise	POPIA s.22(1)	LAW
Hour 4	Incident team convened	Internal	BP
Hour 24	Reasonable-grounds decision recorded	Internal	BP
Hour 72	Regulator notified via eServices; SAPS case opened	POPIA s.22(2) ("as soon as reasonably possible")	BP target for a LAW standard



When	Event	Source	Type
Within 14 days of lodging	Regulator acknowledges a complaint	REG reg 7.6	REG
30 days from receipt	Appeal against enforcement or information notice	POPIA s.97(1)	LAW
3 days from service	Earliest compliance date for an urgent enforcement notice	POPIA s.95	LAW
30 days from service	Pay, arrange instalments or elect trial on an infringement notice	POPIA s.109(2)(d)	LAW
180 days	Complainant's appeal against investigation result	POPIA s.97(2)	LAW

Annual compliance calendar

When	Activity	Step	Type
Monthly	Metrics to IO; screen marketing lists against the National Opt-Out Registry	5.1, 0.13	BP / LAW (CPA s.11; Amendment Regulations 2026)
Quarterly	Retention run; horizon scan; PSC meeting	5.7, 5.10	BP
1 April – 30 June	PAIA annual report on eServices	5.2	LAW / GN
Six-monthly	Board privacy report	0.20	BP
Annually	Registration check; manual update; inventory refresh; operator assurance; security tests; incident tabletop; training; audit; annual report	5.3–5.9	BP
December 2026	Direct marketers registered with the NCC Opt-Out Registry (registration opened 15 September 2026)	0.13	LAW (CPA s.11; Amendment Regulations 2026)
May 2027	Consumers can register blocks on the Opt-Out Registry	0.13	LAW (CPA s.11; Amendment Regulations 2026)



Offences and penalties register

Offence	Who is exposed	Maximum penalty	Authority
Hindering, obstructing or unlawfully influencing the Regulator	Any person	Fine or 10 years, or both	POPIA s.100, s.107(a)
Failing to comply with an enforcement notice	Responsible party	Fine or 10 years, or both	POPIA s.103(1), s.107(a)
False or reckless statement in response to an information notice	Responsible party	Fine or 12 months, or both	POPIA s.103(2), s.107(b)
False evidence on oath before the Regulator	Witness	Fine or 10 years, or both	POPIA s.104(2), s.107(a)
Failing to attend or answer as a witness	Witness	Fine or 12 months, or both	POPIA s.104(1), s.107(b)
Unlawful acts by a responsible party in connection with account numbers	Responsible party	Fine or 10 years, or both	POPIA s.105(1), s.107(a)
Unlawful acts by third parties in connection with account numbers (obtaining, disclosing, selling)	Any person, including employees	Fine or 10 years, or both	POPIA s.106(1), (3), (4), s.107(a)
Processing without required prior authorisation notification	Responsible party	Fine or 12 months, or both	POPIA s.59, s.107(b)
Obstructing execution of a warrant	Any person	Fine or 12 months, or both	POPIA s.102, s.107(b)
Breach of confidentiality by Regulator staff	Regulator members and staff	Fine or 12 months, or both	POPIA s.101, s.107(b)
Administrative fine (in place of prosecution)	Responsible party alleged to have committed an offence	Up to R10 million; instalments allowed	POPIA s.109(2)(d); REG reg 13 (affordability procedure)
Civil damages	Responsible party	Patrimonial, non-patrimonial and aggravated damages; costs	POPIA s.99



Offence	Who is exposed	Maximum penalty	Authority
PAIA offences (destroying records to deny access; wilful or grossly negligent failure to comply with s.51)	Head of private body, IO	Fine or imprisonment up to 2 years, or both	PAIA s.90(1), s.90(3)

Fines imposed to date (as publicly reported). Department of Justice R5 million (s.19; reported as still in dispute, September 2026); Department of Basic Education R5 million (set aside by the High Court in December 2025; leave to appeal refused June 2026; Regulator pursuing a further appeal); Independent Electoral Commission R100 000 (paid); Lancet Laboratories R100 000 (s.22; paid); Blouberg Local Municipality R500 000, reduced by a court to R250 000; FT Rams Consulting R100 000 (direct marketing; in recovery). The pattern is that fines follow ignored enforcement notices, not first offences.

Source review, drafting issues and sources

Source review

Item	Status	Check (19 October 2026)
POPIA 4 of 2013	LAW	Fully in force; grace period ended 30 June 2021.
POPIA Regulations 2018, as amended	REG	Amendments GN 6126, GG 52523, 17 April 2025, immediate effect. Regs 1, 2, 3, 4, 5, 6, 7, 13 and Forms 1–5 amended; Forms 17–19 deleted.
Health information regulations	REG	GN 7198, GG 54268, 6 March 2026, in force on publication; employers broadly defined; made under s.32(6). Duty of confidentiality may arise from law, office, employment, profession or written agreement (the draft's written-agreement requirement was dropped).

Item	Status	Check (19 October 2026)
eServices compromise reporting	GN	Mandatory portal reporting announced in the media statement of 7 April 2025, effective from 1 April 2025.
IO guidance note	GN	Dated 1 April 2021; republished on the Regulator's site in 2025.
Prior authorisation guidance note	GN	Revised January 2024; s.58(2) applied from 1 February 2022.
Direct marketing guidance note	GN	3 December 2024; treats telephone calls as electronic communication. Telephone marketing referrals (OUTsurance, MTN) were pending before the Enforcement Committee in 2026.
PAIA Regulations 2021	REG	GG 45057, 27 August 2021; private body request fee R140; search fee R145 per hour after the first hour, capped at R435; deposit one third over six hours (Regulator fee schedule, March 2026).
PAIA s.83(4) annual report	GN	Window 1 April – 30 June via eServices.
Cybercrimes Act s.54	DRAFT	Not yet in operation (MJK, reviewed 1 July 2026); main offence provisions in force since 1 December 2021.
CPA National Opt-Out Registry	LAW (CPA)	Launched 7 October 2026; marketer registration from 15 September 2026; register by December 2026; monthly list cleansing; consumer blocks from May 2027 (NCC statement, gov.za). The Gazette number of the CPA Amendment Regulations 2026 is still to be confirmed.
POPIA amendment	DRAFT	Regulator reports an internal draft to move to direct consequences for intentional non-compliance; no Bill published.
PIIA guidance note	DRAFT	Planned in the Regulator's 2026/27 performance plan.
DBE matric results matter	CL	Gauteng full bench set aside the notices on 12 December 2025; leave to appeal refused June 2026; the Regulator is pursuing a further appeal and the fine was reported as still in dispute on 1 September 2026.



Drafting issues worth raising

1. **No hard notification clock.** Section 22(2) gives no number of hours. Organisations set their own targets, which makes enforcement inconsistent. A 72-hour outer limit, as in other regimes, would help.

2. **Regulation 3 timing.** Amended reg 3 requires notice of the action taken within 30 days "of receiving the outcome of the request". The responsible party produces the outcome itself, so the start date is unclear. This flow counts from receipt of the request.

3. **Citation error in amended reg 1.** The definition of "writing" refers to the Electronic Communications and Transactions Act 25 of 2002 but gives the year as 2022.

4. **"Approach once" for consent.** Section 69(2)(b) allows one approach to request consent. The guidance note's treatment of telephone calls as electronic communication extends that limit to voice calls, which is contested and awaits Enforcement Committee decisions.

5. **Personnel rules under s.33.** The general authorisation for processing personnel information about criminal behaviour or biometrics refers to rules "established in compliance with labour legislation", which no instrument defines.

6. **Health regulations: no transition period.** The 2026 regulations applied from publication, with a broad definition of employer, and no grace period for updating contracts and HR systems.

7. **Fine only after non-compliance in practice.** The Regulator has said that a party that complies within the period of an enforcement notice cannot then be fined, which weakens deterrence. It is drafting amendments.

8. **Pseudonymised identifiers.** The matric judgment held that publishing results with examination numbers but no names was not processing of personal information. That sits uneasily with the s.1 definition, which includes "any identifying number", and is under appeal.

9. **s.57(1)(a) "unique identifiers".** The scope of linking identifiers "with information processed by other responsible parties" is wide enough to catch ordinary employee-number integrations with payroll bureaus. Guidance is needed.

10. **No AI-specific guidance.** Section 71 has no guidance, although AI recruitment and monitoring tools are spreading. The planned PIIA guidance note should cover AI.

Validation record — v1.0 (19 October 2026)

An independent second-line review on 19 October 2026 found no Critical, 2 Major, 12 Minor and 4 Improvement findings. GBS approved all of them, and each was implemented in this version. The version number stays at v1.0.

#	Finding (severity)	Where	Change made
1	Prior authorisation dates conflated (Major)	0.15	Now states that s.57 processing begun on or after 1 July 2021 needs authorisation (guidance note paras 6.1–6.2), and that the s.58(2) bar on processing applies from 1 February 2022 (para 3.2).
2	Disability data placed under s.29 (Major)	E.5	Race stays under s.29. Disability is now processed as health information under s.32(1)(f)(i) or consent, with s.32(2) confidentiality and the 2026 health regulations.
3	4- and 13-week periods labelled GN; s.58(6)–(7) missing (Minor)	1.7; timeline	Cited s.58(3), s.58(4) as LAW. Added the deemed favourable decision (s.58(7)) and the unlawfulness statement treated as an enforcement notice (s.58(6)).
4	Instalments presented as new in 2025 (Minor)	Figures in force; 4.11; offences register; timeline	Instalments now cited to s.109(2)(d). Reg 13 is described as the 2025 affordability procedure.
5	"LRA Schedule" outdated (Minor)	3.10; interfaces register	Replaced with LRA s.188 and the Code of Good Practice: Dismissal, 2025 (GN 3470, GG 53294).
6	Health regulations' confidentiality overstated as "written" (Minor)	0.12; E.6; source review	Duty may arise by law, office, employment, profession or written agreement. The PO42 undertaking is kept as BP evidence.
7	s.76(3) mischaracterised (Minor)	4.6	Trigger now cites the s.89 assessment and the s.76(3) own-initiative investigation.
8	PAIA fees incomplete (Minor)	Figures in force; 2A.7; source review	Added the R140 request fee, the first-hour exclusion and the mandatory one-third deposit over six hours (PAIA s.54(2)–(4)).
9	s.30 cited for employer union data (Minor)	E.7	Removed s.30 and kept s.27(1)(b) with LRA s.13.
10	Master diagram parallel events did not match P1–P10 (Minor)	Section 2 diagram	Diagram regenerated: "Regulator information notice" removed; children (P9) and deceased (P10) listed separately.



#	Finding (severity)	Where	Change made
11	CJC TVET notice imprecisely described (Minor)	E.3	Now cites the notice for vetting reports circulated to staff (s.15, s.19, s.22).
12	Online prior authorisation and exemption applications unverified (Minor)	0.16	Now refers to the channels in guidance note para 6.3 (email, post, hand delivery), or eServices if offered.
13	eServices date and notification figures (Minor)	Phase 3 intro; source review	Mandatory from 1 April 2025 (statement of 7 April 2025). More than 8 000 notifications to date; more than 1 220 since 1 April 2026.
14	Status of the DBE and DoJ fines (Minor)	Fines register; 4.9; source review	Updated: DBE notices set aside December 2025, leave refused June 2026, Regulator pursuing a further appeal; DoJ fine still in dispute.
15	Resolvable "(verify)" items (Improvement)	E.3; P10; 2A.6; 3.5; 0.13; offences register; calendar	Resolved: NCA reg 18(4)(g) and 19(12); PAIA s.63(2)(e); PAIA s.71 21-day periods; PAIA s.90(3) (2 years); Cybercrimes s.54 not in operation; Opt-Out Registry dates.
16	Information notice safeguards missing (Improvement)	4.5	Added the appeal-period deferral, the 3-day minimum for urgent notices and the privilege protections (s.90(3)–(8)).
17	Reg 4 citations (Improvement)	0.5; 0.17	Cited reg 4(1)(d) for request handling. Noted that reg 4(1)(c) was deleted, so the manual duty rests on PAIA s.51 (offence s.90(3)).
18	CJC enforcement basis (Improvement)	0.3	Added s.8 as the basis the Regulator relied on for the registration order.
—	Open items	Various	Still to confirm: (a) the Gazette number of the CPA Amendment Regulations 2026; (b) IO guidance note paragraph numbers; (c) the lettering of reg 4(1)(b) and (e) after the 2025 deletion; (d) RICA s.6 wording, and the BCEA s.31 and Tax Administration Act s.29 retention periods (still marked "verify"); (e) the planned PIIA guidance note and the POPIA amendment draft (DRAFT); (f) the outcome of the DBE appeal.

Sources

- Protection of Personal Information Act 4 of 2013 (sections cited from the consolidated text at popia.co.za, including s.95, s.97, s.107 and s.109, checked 19 October 2026).

- Regulations Relating to the Protection of Personal Information, 2018 (GN R1383, GG 42110) as amended by GN 6126, GG 52523, 17 April 2025: Information Regulator final text (inforegulator.org.za); Acts Online notice summary; GoLegal, "New amendments to POPIA Regulations", 23 April 2025.
- Regulations Relating to the Processing of Data Subjects' Health Information by Certain Responsible Parties, 2026 (GG 54268, 6 March 2026): Fasken (April 2026); ITWeb, "POPIA: New health information regulations – what every employer must know", 24 April 2026; Moonstone (March 2026).
- Information Regulator, Guidance Note on Information Officers and Deputy Information Officers (1 April 2021, republished 2025).
- Information Regulator, Revised Guidance Note on Applications for Prior Authorisation (January 2024).
- Information Regulator, Guidance Note on Direct Marketing (3 December 2024): Cliffe Dekker Hofmeyr summary, 29 January 2025.
- Information Regulator, security compromise guidelines and form (August 2022): Power Law Africa, 15 August 2022; eServices portal reporting: Moonstone, 10 April 2025; Covington Inside Privacy (April 2025).
- Information Regulator, PAIA annual report page (inforegulator.org.za/paia-annual-report).
- Information Regulator media statement, enforcement notices against Central Johannesburg TVET College and Sibanye Stillwater, 2 June 2026; ENSafrica, "Information Regulator's first enforcement notice for 2026", 1 June 2026.
- Michalsons, "Information Regulator ramps up enforcement" (September 2026); ITLawCo, "Information Regulator briefing 2026" and "2026/27 Annual Performance Plan"; MJK, POPIA enforcement tracker (2026).
- Moonstone, "Matric results row rolls into 2026" (January 2026); IOL, 3 June 2026 (leave to appeal refused).
- Promotion of Access to Information Act 2 of 2000 and PAIA Regulations 2021 (GG 45057): Cliffe Dekker Hofmeyr, 6 September 2021; Information Regulator PAIA forms page.
- Cybercrimes Act 19 of 2020, s.54 status: MJK (reviewed 1 July 2026); Engineering News, 19 July 2024.
- National Opt-Out Registry: SAnews, 7 October 2026.
- National Consumer Commission, "National Consumer Commission launches National Opt-Out Registry", 7 October 2026 (gov.za).
- Information Regulator, Revised Guidance Note on Applications for Prior Authorisation (January 2024), paras 3.2, 6.1–6.3, 7.1.
- Information Regulator, PAIA private body fee structure (March 2026) and PAIA annual report page.
- Amended POPIA Regulations, final text (inforegulator.org.za, "POPIA-2021-Regulations-FINAL-21-Jan-2025"); Acts Online, definitions (reg 1).
- Bowmans, "POPIA health information regulations cross the finish line", 12 March 2026; Fasken, "Health data under the microscope", April 2026.



- Moonstone, "When a misdirected email becomes a POPIA enforcement case" (2026); Information Regulator media statement, 2 June 2026.
- BusinessTech, "Two departments nailed with R5 million fines", 1 September 2026.
- PAIA s.54, s.71 and s.90 (Acts Online); NCA Regulations reg 18(4)(g) and reg 19(12) (Experian NCA note).
- Independent validation report: GBS second-line review, 19 October 2026 (18 findings, all implemented; see the validation record).
- Case law: *Smuts v Botha* [2022] ZASCA 3; *Munetsi v Madhuyu and Another* (Western Cape High Court, 2024; Cliffe Dekker Hofmeyr summary, 18 September 2024); *Zulu Nyala Game Ranch (Pty) Ltd v Beukes* [2025] ZAKZDHC 87 (GoLegal, 4 February 2026); *Arena Holdings (Pty) Ltd t/a Financial Mail v SARS* [2023] ZACC 13; Department of Basic Education matter (Gauteng Division, full bench, 12 December 2025).
- BCEA, EEA, LRA, RICA, NCA Regulations, Tax Administration Act and CPA provisions are cited from general knowledge and the GBS flows; verify section wording and retention periods against consolidated texts before adoption.

This flow is a working document for legal review, not legal advice.